VibeProofLens AUDIT
CLIENT PORTAL

CLIENT READ-ONLY 22:44:31

Dhakshini D
RIVERDALE COLLEGE

CLIENT PROOF & VERIFICATION
- Release Sa... PLAIN-ENGLISH
- Verify Delivered ZIP ED25519

DELIVERY INTEGRITY & EVIDENCE
- Immutable Audit ... SHA-256
- Live Domain & D... LIVE DNS
- Security & OW... STANDARDS

CLIENT PORTAL / **Projects**   Quick search... ⌘K   Demo Sandbox   CLIENT VERIFIED

← SCORECARD (CAMPUSONE ERP) • CLIENT ADVISORY CATALOG

Plain-Language Advisory Explanations

SAMPLE DATA   Approve Baseline

What each discovered security flaw means for Riverdale College and how it affects risk.

Search findings by title, risk impact, rule ID, or architectural layer...

All (48) Critical (5) High (23) Medium (18) Low (2)

MEDIUM **CFG-002** • Code Layer   In-browser   Advisory template text

Dockerfile Without Dedicated USER Instruction

Institutional Client Explanation (Executive Summary)

The server container runs with unrestricted root permissions. If an attacker manages to breach any part of the web server, they immediately have full administrator control over the underlying operating system.

Affected File & Asset: Confidence: high

`Dockerfile:1`

HIGH **CFG-003** • Code Layer   In-browser   Advisory template text

Dockerfile ENV Direct Sensitive Credential Assignment

Institutional Client Explanation (Executive Summary)

The container build configuration includes passwords or secret keys directly inside the Dockerfile. Anyone who downloads the container image can extract these secrets using standard image inspection tools.

Affected File & Asset: Confidence: high

`Dockerfile:6`

MEDIUM **CFG-001** • Code Layer   In-browser   Advisory template text

Debug / Development Mode Committed to Archive

Institutional Client Explanation (Executive Summary)

The application has diagnostic debug mode switched on. When an error occurs, it displays detailed internal server blueprints and technical source code to public website visitors.

Affected File & Asset: Confidence: high

`Dockerfile:7`

HIGH **SEC-002** • Code Layer   In-browser   Advisory template text

Committed Environment Configuration File (.env)

Institutional Client Explanation (Executive Summary)

An internal environment configuration file (.env) was packaged directly inside the production source code bundle. These files typically contain database credentials, private signing keys, and administrative endpoints that should never be distributed with release archives.

Affected File & Asset: Confidence: high

`.env:1`

MEDIUM **CFG-001** • Code Layer   In-browser   Advisory template text

Debug / Development Mode Committed to Archive

Institutional Client Explanation (Executive Summary)

The application has diagnostic debug mode switched on. When an error occurs, it displays detailed internal server blueprints and technical source code to public website visitors.

Affected File & Asset: Confidence: high

`.env:1`

MEDIUM **CFG-001** • Code Layer   In-browser   Advisory template text

Debug / Development Mode Committed to Archive

Institutional Client Explanation (Executive Summary)

The application has diagnostic debug mode switched on. When an error occurs, it displays detailed internal server blueprints and technical source code to public website visitors.

Affected File & Asset: Confidence: high

`.env:2`

HIGH **SEC-004** • Code Layer   In-browser   Advisory template text

Database Connection String with Embedded Credentials

Institutional Client Explanation (Executive Summary)

The application database connection string contains the database username and password in plain text. If an unauthorized person inspects the code, they have direct access to read, modify, or delete college student records.

Affected File & Asset: Confidence: high

`.env:4`

HIGH **SEC-001** • Code Layer   In-browser   Advisory template text

Hardcoded API Key / Secret Literal

Institutional Client Explanation (Executive Summary)

A sensitive credential (like an external API key or third-party token) was directly written into the application's source code. If this codebase is shared, inspected, or leaked, unauthorized third parties could access protected external services under your organization's account.

Affected File & Asset: Confidence: medium

`.env:5`

HIGH **SEC-001** • Code Layer   In-browser   Advisory template text

Hardcoded API Key / Secret Literal

Institutional Client Explanation (Executive Summary)

A sensitive credential (like an external API key or third-party token) was directly written into the application's source code. If this codebase is shared, inspected, or leaked, unauthorized third parties could access protected external services under your organization's account.

Affected File & Asset: Confidence: medium

`.env:6`

HIGH **SEC-001** • Code Layer   In-browser   Advisory template text

Hardcoded API Key / Secret Literal

Institutional Client Explanation (Executive Summary)

A sensitive credential (like an external API key or third-party token) was directly written into the application's source code. If this codebase is shared, inspected, or leaked, unauthorized third parties could access protected external services under your organization's account.

Affected File & Asset: Confidence: medium

`.env:7`

HIGH **SEC-001** • Code Layer   In-browser   Advisory template text

Hardcoded API Key / Secret Literal

Institutional Client Explanation (Executive Summary)

A sensitive credential (like an external API key or third-party token) was directly written into the application's source code. If this codebase is shared, inspected, or leaked, unauthorized third parties could access protected external services under your organization's account.

Affected File & Asset: Confidence: medium

`client/dashboard.js:3`

MEDIUM **SEC-005** • Code Layer   In-browser   Advisory template text

High-Entropy Secret Literal Detected in Source

Institutional Client Explanation (Executive Summary)

A high-entropy random string resembling an encryption key or authentication token was found in the application code. This poses a risk of unauthorized service access if it represents an active production credential.

Affected File & Asset: Confidence: low

`client/dashboard.js:3`

MEDIUM **COD-007** • Code Layer   In-browser   Advisory template text

Direct HTML Injection via innerHTML / dangerouslySetInnerHTML

Institutional Client Explanation (Executive Summary)

Dynamic data is directly injected into the webpage as raw HTML. If an attacker puts script code into a student note or profile, it can execute inside other users' browsers (Cross-Site Scripting).

Affected File & Asset: Confidence: medium

`client/dashboard.js:9`

CRITICAL **SEC-003** • Code Layer   In-browser   Advisory template text

Hardcoded Secret in JWT Sign / Verify

Institutional Client Explanation (Executive Summary)

The cryptographic secret used to sign user authentication tokens (JWTs) is hardcoded as plain text. Anyone who views this code can forge administrative identity tokens and log in as any user or student without a password.

Affected File & Asset: Confidence: high

`server.js:32`

MEDIUM **COD-005** • Code Layer   In-browser   Advisory template text

Cookie Issued Without Secure or HttpOnly Flags

Institutional Client Explanation (Executive Summary)

Session cookies are sent without security flags that protect them from being stolen by malicious scripts or eavesdropped on unencrypted connections.

Affected File & Asset: Confidence: medium

`server.js:39`

HIGH **COD-004** • Code Layer   In-browser   Advisory template text

Unprotected Administrative Endpoint Without Auth Middleware

Institutional Client Explanation (Executive Summary)

An administrative route (such as /admin/export) was defined without required login or permission checking. Unauthenticated visitors can trigger administrative exports or actions.

Affected File & Asset: Confidence: low

`server.js:67`

MEDIUM **COD-003** • Code Layer   In-browser   Advisory template text

Permissive Wildcard Cross-Origin Resource Sharing (CORS)

Institutional Client Explanation (Executive Summary)

The server allows any website on the internet to send background requests and read responses on behalf of logged-in users. This could allow phishing sites to read sensitive student profiles.

Affected File & Asset: Confidence: high

`server.js:11`

HIGH **SEC-001** • Code Layer   In-browser   Advisory template text

Hardcoded API Key / Secret Literal

Institutional Client Explanation (Executive Summary)

A sensitive credential (like an external API key or third-party token) was directly written into the application's source code. If this codebase is shared, inspected, or leaked, unauthorized third parties could access protected external services under your organization's account.

Affected File & Asset: Confidence: medium

`server.js:17`

HIGH **SEC-001** • Code Layer   In-browser   Advisory template text

Hardcoded API Key / Secret Literal

Institutional Client Explanation (Executive Summary)

A sensitive credential (like an external API key or third-party token) was directly written into the application's source code. If this codebase is shared, inspected, or leaked, unauthorized third parties could access protected external services under your organization's account.

Affected File & Asset: Confidence: medium

`server.js:18`

MEDIUM **SEC-005** • Code Layer   In-browser   Advisory template text

High-Entropy Secret Literal Detected in Source

Institutional Client Explanation (Executive Summary)

A high-entropy random string resembling an encryption key or authentication token was found in the application code. This poses a risk of unauthorized service access if it represents an active production credential.

Affected File & Asset: Confidence: low

`server.js:18`

HIGH **COD-006** • Code Layer   In-browser   Advisory template text

Plain-text Password Comparison Without Constant-time Hash

Institutional Client Explanation (Executive Summary)

The application compares student passwords directly using plain-text comparisons instead of industry standard cryptographic password hashing. This leaves passwords vulnerable to timing attacks and database exposure.

Affected File & Asset: Confidence: medium

`server.js:27`

HIGH **COD-001** • Code Layer   In-browser   Advisory template text

SQL Query Built with Unsafe String Concatenation

Institutional Client Explanation (Executive Summary)

User-provided text is pasted directly into database search queries without proper sanitization. A malicious actor could type special characters to trick the database into revealing all student transcripts or financial records.

Affected File & Asset: Confidence: medium

`server.js:46`

HIGH **COD-002** • Code Layer   In-browser   Advisory template text

Dynamic Code Execution (eval / new Function)

Institutional Client Explanation (Executive Summary)

The application dynamically executes computer code constructed from runtime data. This allows an attacker to send custom commands that the server executes, potentially giving them full control over the server environment.

Affected File & Asset: Confidence: high

`server.js:59`

MEDIUM **COD-008** • Code Layer   In-browser   Advisory template text

Cryptographically Insecure Random Generator Used for Token

Institutional Client Explanation (Executive Summary)

Password reset or authentication tokens are generated using a predictable random number generator. Attackers can predict future tokens and hijack accounts.

Affected File & Asset: Confidence: medium

`server.js:78`

HIGH **SEC-001** • Code Layer   In-browser   Advisory template text

Hardcoded API Key / Secret Literal

Institutional Client Explanation (Executive Summary)

A sensitive credential (like an external API key or third-party token) was directly written into the application's source code. If this codebase is shared, inspected, or leaked, unauthorized third parties could access protected external services under your organization's account.

Affected File & Asset: Confidence: medium

`src/config.js:2`

MEDIUM **SEC-005** • Code Layer   In-browser   Advisory template text

High-Entropy Secret Literal Detected in Source

Institutional Client Explanation (Executive Summary)

A high-entropy random string resembling an encryption key or authentication token was found in the application code. This poses a risk of unauthorized service access if it represents an active production credential.

Affected File & Asset: Confidence: low

`src/config.js:2`

HIGH **SEC-001** • Code Layer   In-browser   Advisory template text

Hardcoded API Key / Secret Literal

Institutional Client Explanation (Executive Summary)

A sensitive credential (like an external API key or third-party token) was directly written into the application's source code. If this codebase is shared, inspected, or leaked, unauthorized third parties could access protected external services under your organization's account.

Affected File & Asset: Confidence: medium

`src/config.js:3`

MEDIUM **SEC-005** • Code Layer   In-browser   Advisory template text

High-Entropy Secret Literal Detected in Source

Institutional Client Explanation (Executive Summary)

A high-entropy random string resembling an encryption key or authentication token was found in the application code. This poses a risk of unauthorized service access if it represents an active production credential.

Affected File & Asset: Confidence: low

`src/config.js:3`

HIGH **SEC-001** • Code Layer   In-browser   Advisory template text

Hardcoded API Key / Secret Literal

Institutional Client Explanation (Executive Summary)

A sensitive credential (like an external API key or third-party token) was directly written into the application's source code. If this codebase is shared, inspected, or leaked, unauthorized third parties could access protected external services under your organization's account.

Affected File & Asset: Confidence: medium

`src/config.js:6`

HIGH **DEP-001** • Code Layer   In-browser   Advisory template text

Vulnerable Dependency: axios@0.21.0 (CVE-2020-28168)

Institutional Client Explanation (Executive Summary)

The software relies on an outdated third-party code library that has publicly documented security flaws (CVEs). Attackers can exploit well-known automated tools against known library vulnerabilities to disrupt operations or extract data.

Affected File & Asset: Confidence: high

`package.json:11`

MEDIUM **DEP-001** • Code Layer   In-browser   Advisory template text

Vulnerable Dependency: express@4.17.1 (CVE-2024-29041)

Institutional Client Explanation (Executive Summary)

The software relies on an outdated third-party code library that has publicly documented security flaws (CVEs). Attackers can exploit well-known automated tools against known library vulnerabilities to disrupt operations or extract data.

Affected File & Asset: Confidence: high

`package.json:14`

HIGH **DEP-001** • Code Layer   In-browser   Advisory template text

Vulnerable Dependency: jsonwebtoken@8.5.1 (CVE-2022-23529)

Institutional Client Explanation (Executive Summary)

The software relies on an outdated third-party code library that has publicly documented security flaws (CVEs). Attackers can exploit well-known automated tools against known library vulnerabilities to disrupt operations or extract data.

Affected File & Asset: Confidence: high

`package.json:15`

HIGH **DEP-001** • Code Layer   In-browser   Advisory template text

Vulnerable Dependency: lodash@4.17.15 (CVE-2021-23337)

Institutional Client Explanation (Executive Summary)

The software relies on an outdated third-party code library that has publicly documented security flaws (CVEs). Attackers can exploit well-known automated tools against known library vulnerabilities to disrupt operations or extract data.

Affected File & Asset: Confidence: high

`package.json:16`

HIGH **DBA-001** • Database Layer   In-browser   Advisory template text

Database Table Missing Row Level Security (RLS)

Institutional Client Explanation (Executive Summary)

The database table storing confidential records lacks row-by-row access control. If the client application requests data, the database does not independently verify whether the user is permitted to see that specific row.

Affected File & Asset: Confidence: high

`supabase/migrations/001_init.sql:2`

HIGH **DBA-001** • Database Layer   In-browser   Advisory template text

Database Table Missing Row Level Security (RLS)

Institutional Client Explanation (Executive Summary)

The database table storing confidential records lacks row-by-row access control. If the client application requests data, the database does not independently verify whether the user is permitted to see that specific row.

Affected File & Asset: Confidence: high

`supabase/migrations/001_init.sql:12`

HIGH **DBA-001** • Database Layer   In-browser   Advisory template text

Database Table Missing Row Level Security (RLS)

Institutional Client Explanation (Executive Summary)

The database table storing confidential records lacks row-by-row access control. If the client application requests data, the database does not independently verify whether the user is permitted to see that specific row.

Affected File & Asset: Confidence: high

`supabase/migrations/001_init.sql:21`

CRITICAL **DBA-002** • Database Layer   In-browser   Advisory template text

Overly Permissive Public Access in Cloud Storage Rules

Institutional Client Explanation (Executive Summary)

The cloud file storage security rules are configured to permit anyone on the internet to upload, download, or delete stored files without authenticating.

Affected File & Asset: Confidence: high

`firebase/storage.rules:6`

CRITICAL **DBA-003** • Database Layer   In-browser   Advisory template text

Database Admin / Service-Role Key Exposed in Client Asset

Institutional Client Explanation (Executive Summary)

An administrative master key that bypasses all security rules was included in files sent directly to web browsers. Visitors can extract this key using browser developer tools and gain full administrative database control.

Affected File & Asset: Confidence: medium

`client/dashboard.js:3`

CRITICAL **DBA-003** • Database Layer   In-browser   Advisory template text

Database Admin / Service-Role Key Exposed in Client Asset

Institutional Client Explanation (Executive Summary)

An administrative master key that bypasses all security rules was included in files sent directly to web browsers. Visitors can extract this key using browser developer tools and gain full administrative database control.

Affected File & Asset: Confidence: medium

`client/dashboard.js:14`

CRITICAL **EXP-001** • Website Layer   SAMPLE DATA   Advisory template text

Environment Configuration File (.env) Publicly Exposed via HTTP

Institutional Client Explanation (Executive Summary)

The server's internal configuration file is directly downloadable by anyone visiting `https://your-domain.com/.env`. This immediately leaks all secret passwords and keys to anyone on the web.

Affected File & Asset: Confidence: high

`https://campusone-demo.example/.env:1`

HIGH **EXP-002** • Website Layer   SAMPLE DATA   Advisory template text

Git Repository Metadata (/.git/HEAD) Publicly Reachable

Institutional Client Explanation (Executive Summary)

The internal Git version control folder of the application is publicly accessible on the live website. Malicious actors could download your complete source code repository and internal development commit messages.

Affected File & Asset: Confidence: high

`https://campusone-demo.example/.git/HEAD:1`

MEDIUM **WEB-001** • Website Layer SAMPLE DATA Advisory template text

Missing Content-Security-Policy (CSP) Header

Institutional Client Explanation (Executive Summary)

The website does not restrict which external scripts, images, and frames are allowed to load. This leaves users susceptible to Cross-Site Scripting (XSS) attacks where rogue scripts steal session credentials.

Affected File & Asset: Confidence: high

`https://campusone-demo.example/:1`

MEDIUM **WEB-003** • Website Layer SAMPLE DATA Advisory template text

Session Cookie Issued Without Secure and HttpOnly Flags

Institutional Client Explanation (Executive Summary)

Login cookies can be read by JavaScript scripts running on the page and transmitted over unencrypted connections. If an attacker injects a script, they can steal the user's active session without knowing their password.

Affected File & Asset: Confidence: high

`https://campusone-demo.example/api/login:1`

LOW **WEB-004** • Website Layer SAMPLE DATA Advisory template text

Missing X-Frame-Options Clickjacking Protection

Institutional Client Explanation (Executive Summary)

The web page does not declare whether it can be embedded inside invisible frames on third-party sites. Attackers could attempt 'clickjacking' to trick users into clicking buttons without their knowledge.

Affected File & Asset: Confidence: high

`https://campusone-demo.example/:1`

LOW **EXP-003** • Website Layer SAMPLE DATA Advisory template text

Production JavaScript Source Maps Reachable via HTTP

Institutional Client Explanation (Executive Summary)

Original unminified source code maps were published to the live public website. While not a direct security breach, this allows competitors or reverse-engineers to read original comments and internal architecture.

Affected File & Asset: Confidence: high

`https://campusone-demo.example/bundle.js.map:1`

MEDIUM **TLS-001** • Hosting and Domain Layer SAMPLE DATA Advisory template text

Plain HTTP Insecure Request Allowed Without HTTPS Redirect

Institutional Client Explanation (Executive Summary)

Visitors who type `http://` instead of `https://` are not automatically redirected to the secure encrypted version of the website. Network eavesdroppers on public Wi-Fi could view unencrypted student traffic.

Affected File & Asset: Confidence: high

`http://campusone-demo.example/:1`

MEDIUM **TLS-002** • Hosting and Domain Layer SAMPLE DATA Advisory template text

SSL/TLS Certificate Nearing Expiration (< 14 Days Remaining)

Institutional Client Explanation (Executive Summary)

The security certificate that encrypts your college website traffic is about to expire within 14 days. If it expires, all web browsers will display a scary red security warning preventing students from logging in.

Affected File & Asset: Confidence: high

`campusone-demo.example:443:1`

MEDIUM **TLS-003** • Hosting and Domain Layer SAMPLE DATA Advisory template text

HTTP Strict Transport Security (HSTS) Header Missing

Institutional Client Explanation (Executive Summary)

The website does not instruct web browsers to strictly enforce HTTPS connections on future visits. An attacker on the local network could downgrade student connections to unencrypted HTTP.

Affected File & Asset: Confidence: high

`https://campusone-demo.example/:1`

VibeProofLens SAAS EDITION ● ED25519 LIVE

Pre-delivery security verification & cryptographic handover seals for AI-built web applications. Catch leaked keys, inspect database RLS, and hand over tamper-proof client proof.

Threat Breakers (DEX26123) • SIST MCA, Chennai • **DEXATHON 2026**

Get AI Security Advisories QUARTERLY CVE BRIEF

Curated zero-day secret leak patterns, AI assistant blindspots, and freelance client delivery protection tips.

developer@domain.com **Subscribe →**

Zero spam · In-browser privacy 1-click instant unsubscribe

SECURITY ENGINE
- **Judges: Start Here (Roadmap)**
- In-Browser AST Scanner
- ZeroLeak Prompt Redactor
- Noble Ed25519 Seals
- 6-Layer Scorecard
- 1-Click AI Fix Prompts
- A4 Printable Audit PDFs

PLATFORM PORTALS
- Hub
- Client Portal
- Admin Governance Gateway
- Role Architecture Tour
- Direct Token Verification
- Client Onboarding Suite

PLANS & INVOICING

Solo Developer	₹0
Developer Pro	₹3,999/mo
Agency Team	₹14,999/mo

- **25+ Feature Matrix**
- 18% IGST (SAC 998314)
- Hub Quotas

STANDARDS & OWASP
- Security Knowledge Base
- OWASP Top 10 Matrix
- Readiness Self-Audit
- AI Code Security Blindspot
- CWE-798 Secret Audit
- Ed25519 Release Sealing

INSTITUTION & TEAM

Threat Breakers
Team DEX26123 · SIST
Sathyabama Institute of Science and Technology, Chennai
Department of Computer Applications (MCA)
5.0 Verified Reviews
Security FAQ

● SYSTEM OPERATIONAL 20+ AST Engines Active • FIPS 180-4 SHA-256 • Noble Curve Ed25519 • **SAC 998314 Compliant** Self Sign-up • Client Portal • **Admin Portal**

© 2026 VibeProofLens. All rights reserved. · Developed for DEXATHON 2026 by Threat Breakers · Official Tax Invoices SAC 998314 (18% IGST)

QUICK PORTAL JUMP

Hub Admin Root

Seals are cryptographically signed with Noble Curve Ed25519 signatures. Data is read-only.

DD **Dhakshi...** CLIENT TIER 3
dhakshini.d@riverdale.e...